

# Post-Quantum IPsec and IKEv2: Securing Enterprise VPNs with RFC 9370, RFC 9242, and ML-KEM

Day 07 | Category: Virtual Private Networks (VPN) & Enterprise Security

Date: 2026-07-14 | **DAILY**  
**MONITORING**

## Introduction: The Quantum Threat to Enterprise VPNs

Enterprise virtual private networks (VPNs) rely heavily on **IPsec (Internet Protocol Security)** and its control plane protocol, **IKEv2 (Internet Key Exchange Protocol Version 2)**, to establish secure cryptographic tunnels across untrusted networks. Traditionally, peers use classical Diffie-Hellman (DH) or Elliptic Curve Diffie-Hellman (ECDH) during the `IKE_SA_INIT` phase to agree upon session keys. However, classical public-key cryptography is highly vulnerable to future quantum computers running Shor's algorithm, exposing enterprise traffic to "Harvest-Now, Decrypt-Later" (HNDL) attacks.

**Harvest-Now, Decrypt-Later (HNDL):** Passive adversaries record today's encrypted VPN handshake and payload traffic. Once a cryptographically relevant quantum computer (CRQC) is built, they can decrypt the historical sessions, exposing sensitive corporate data, credentials, and proprietary intellectual property.

## RFC 9370: Enabling Multiple Key Exchanges in IKEv2

In May 2023, the IETF published **RFC 9370**, which extends IKEv2 to allow multiple key exchanges to take place while establishing a Security Association (SA). Rather than forcing a hard cutover from classical to post-quantum algorithms—which introduces significant migration risk—RFC 9370 standardizes a hybrid approach. This ensures that the derived keys are cryptographically secure as long as *either* the classical or the post-quantum algorithm remains unbroken.

To implement this, RFC 9370 leverages the **IKE\_INTERMEDIATE** exchange (defined in **RFC 9242**). Let's see how the handshake structure is adapted:

- **IKE\_SA\_INIT:** The initiator and responder perform a lightweight, classical key exchange (e.g., using X25519 or ECDH Curve P-256) to establish a baseline encrypted channel. This

lightweight step prevents denial-of-service (DoS) attacks from wasting intensive post-quantum resources.

- **IKE\_INTERMEDIATE:** Within the newly encrypted—but quantum-vulnerable—channel, the peers conduct one or more intermediate exchanges to transmit the larger post-quantum Key Exchange Mechanism (KEM) payloads (e.g., ML-KEM-768).
- **IKE\_AUTH:** Finally, the peers authenticate each other, compile all exchange results, and derive the secure session keys (SKEYSEED) combining both classical and post-quantum shared secrets.

### The Vital Role of IKE\_INTERMEDIATE (RFC 9242)

Post-Quantum algorithms, specifically lattice-based KEMs like ML-KEM, require substantially larger public keys and ciphertexts than their classical counterparts. For instance, an ML-KEM-768 public key is 1,184 bytes, compared to just 32 bytes for X25519. If these payloads were crammed into the initial `IKE_SA_INIT` packet, the message would easily exceed the standard Ethernet Maximum Transmission Unit (MTU) of 1,500 bytes. This would lead to IP fragmentation at the network layer, which is frequently dropped by firewalls and middleboxes, resulting in connection timeouts.

By using `IKE_INTERMEDIATE`, the post-quantum key exchange is performed after the initial encrypted channel is up, allowing the protocol to securely handle larger packets and leverage IKEv2's built-in cryptographic fragmentation capabilities if necessary.

## Real-World Cybersecurity Applicability and 2026 Status

The transition of enterprise IPsec VPNs to post-quantum security is moving from theoretical drafts into active, widespread production deployment. In 2026, several industry leaders have integrated these capabilities:

- **IETF Standard Drafts:** The draft `draft-ietf-ipsecme-ikev2-mlkem` specifies the direct mapping of ML-KEM (FIPS 203) as the additional key exchange under RFC 9370, removing previous interoperability issues caused by non-standardized ciphersuites.
- **Cloudflare One:** Cloudflare has upgraded its SASE (Secure Access Service Edge) platform to support hybrid ML-KEM for IPsec tunnels, enabling enterprise clients to secure their offices, VPCs, and branches against HNDL attacks.
- **Fortinet (FortiOS 7.6.1):** Fortinet's NGFW now supports FIPS 203-compliant ML-KEM-512, ML-KEM-768, and ML-KEM-1024, enabling robust, multi-round hybrid key exchanges.
- **StrongSwan:** The widely used open-source IPsec daemon has seen successful experimental integration of ML-KEM in tandem with hardware acceleration for high-throughput enterprise gateways.

## Key Metrics Comparison: Classical vs. Hybrid vs. Pure PQC

The table below summarizes the trade-offs in parameter sizes, round-trips, and cryptographic resilience across key exchange profiles in IKEv2.

| Key Exchange Method                   | Base Cryptography         | Public Key Size | Ciphertext Size | Quantum Resistance            | Fragmentation Risk                   |
|---------------------------------------|---------------------------|-----------------|-----------------|-------------------------------|--------------------------------------|
| X25519 (Classical)                    | ECDH (Curve25519)         | 32 bytes        | 32 bytes        | None (Vulnerable to CRQC)     | Negligible                           |
| ML-KEM-768 (Pure PQC)                 | Module-Lattice (FIPS 203) | 1,184 bytes     | 1,088 bytes     | Yes (NIST Level 3)            | Moderate (if in IKE_SA_INIT)         |
| Hybrid X25519 + ML-KEM-768 (RFC 9370) | Hybrid (DH + Lattice)     | 1,216 bytes     | 1,120 bytes     | Yes (Failsafe Classical + PQ) | Low (Mitigated via IKE_INTERMEDIATE) |

## Daily Quiz / Auto-Avaliação

### 1. Why doesn't RFC 9370 recommend sending ML-KEM public keys directly in the `IKE_SA_INIT` payload?

- a) Because ML-KEM is not secure enough to be sent in plaintext.
- b) Because ML-KEM's large keys and ciphertexts would trigger IP fragmentation, which is often dropped by firewalls and middleboxes.
- c) Because it would violate the FIPS 203 specification.

*Answer: b) The large size of lattice-based keys exceeds typical MTU limits, and conducting the exchange within `IKE_INTERMEDIATE` prevents fragmentation failures.*

### 2. What is the main security advantage of a hybrid key exchange (e.g., X25519 + ML-KEM-768) over a pure PQC key exchange?

- a) It executes twice as fast as pure PQC.
- b) It satisfies the legal requirements of classical standards while maintaining security if either the classical or post-quantum mathematical assumption holds true.
- c) It uses smaller key sizes than standard ECDH.

*Answer: b) It provides dual security boundaries, acting as a cryptographic failsafe against potential mathematical or implementation flaws in newly standardized PQC algorithms.*

### 3. How does RFC 9370 update the terminology established in RFC 7296 for IKEv2?

- a) Replace IPsec with PQ-IPsec.
- b) It renames Transform Type 4 from "Diffie-Hellman Group (D-H)" to "Key Exchange Method (KE)" to generalize all types of key exchange mechanisms, including KEMs.
- c) It deprecates ESP (Encapsulating Security Payload).

*Answer: b) It generalizes the transform type and fields to easily accommodate non-DH mechanisms like post-quantum key encapsulation.*